



信息安全科技创新

2026年7月



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY



常见网络攻击的检测系统

陈秀真，姚立红

2026年7月



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

目录 Contents

- 1 常见网络攻击
- 2 入侵检测概述
- 3 误用检测模型
- 4 基于特征串匹配的网络攻击检测解析
- 5 常见网络攻击的检测系统开发



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

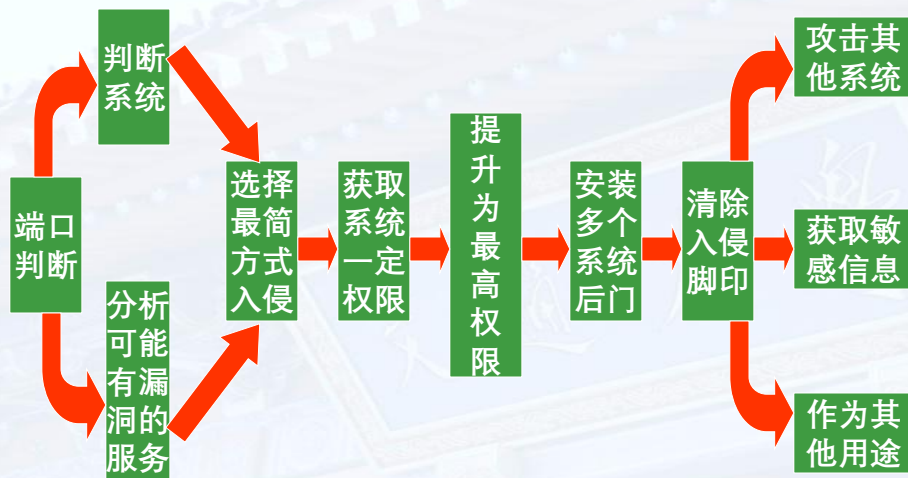
目录 Contents

- 1 常见网络攻击
- 2 入侵检测概述
- 3 误用检测模型
- 4 基于特征串匹配的网络攻击检测解析
- 5 常见网络攻击的检测系统开发



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

网络攻击步骤



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

A类攻击和滥用

- ◆ 通过欺骗网络访问控制而对受限制网络服务进行非授权访问。
- ◆ 也称为登录滥用 (logon abuse)，包括合法用户试图访问禁止其访问的资源，以及外部威胁企图获取网络的访问权。
- ◆ 相关攻击手段：
 - 伪装 (masquerading)：一个用户伪装成另一个用户。例如攻击者通过社会工程 (social engineering) 手段从ISP那里获得一个合法用户口令。避免此类攻击的对策是加强用户意识。
 - 暴力攻击 (brute force)：暴力攻击一般是针对口令破解的。攻击者集聚自己所有的资源，通过反复的尝试过程来获取系统的访问权。进行口令破解时，攻击者不断重复登录过程，希望能够进入系统。避免此类攻击的对策是加强口令策略。



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

B类攻击和滥用

- ◆ 持非业务目的对网络进行非授权使用。 例如有人利用公司资源打印个人信息，或者公然访问未授权的Web网站。
- ◆ B类网络滥用最有效的对策就是定义一个可接受使用策略（acceptable use policy, AUP）和一个强制执行的安全策略，明确指出对资源进行非业务使用的后果。内容过滤和应用代理也可以用来实施单点的访问控制。
- ◆ 主要手段：
 - PBX欺诈和滥用 —— 职员利用公司的电话系统聊天，外部用户呼叫公司并连接某个长途号码。
 - 电子邮件和Internet滥用 —— 特别是病毒传播和防范。从访问不合适的Web站点，到收发与业务无关的邮件和附件，电子邮件和Internet滥用的解决有许多恼人的问题。除了AUP，邮件内容过滤和病毒扫描软件也应该用来保护公司资源。关于Internet滥用，最好是使用代理和Internet建立及阻塞软件，确保职员只能访问公司认为合适的资源。

C类攻击和滥用

- ◆ 窃听（eavesdropping），包括主动或被动的，从偷听某人讲话，到在网络上搭线窃取网络通信。
- ◆ 主要手段：
 - 网络嗅探（Network sniffing） —— 捕获传输中的数据包。网络嗅探可以为操作者提供所有可能用来攻击系统的信息。抵御网络嗅探的一种方法就是使用交换机。最有效的对策是使用加密，例如IPSec，不经过解密的数据是不可读的。
 - 垃圾潜水（Dumpster diving） —— 这是一种社会工程技术。搜寻垃圾，从中找到有价值的东西。其实这也是美国法律中可接受的一种证据采集手段。对付此类滥用最有效的办法就是切碎并烧毁垃圾。合法但不道德
 - 击键记录（Keystroke recording） —— 击键记录可以用来捕获所有输入到计算机中的数据。因为必须要执行捕获数据的程序，而基于主机的IDS或类似系统能够识别允许执行的程序，因而可以防止击键捕获程序的执行。

D类攻击和滥用

◆ 对网络服务和资源的拒绝服务攻击（denial of service, DoS）。

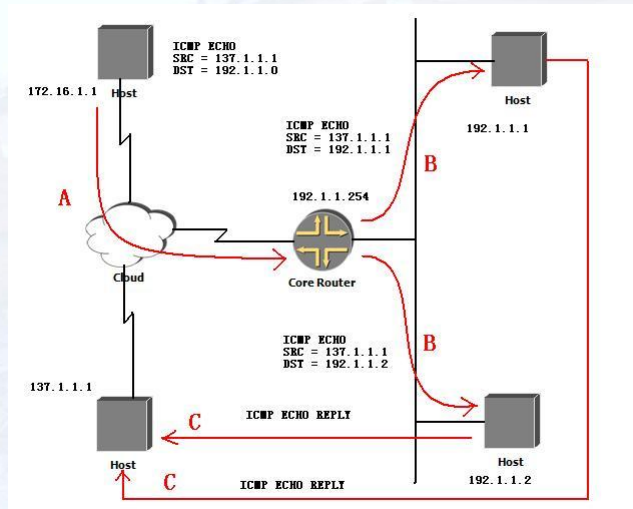
◆ 主要手段：

- SYN Flooding —— 服务器被淹没于开放会话的请求当中，但会话并未真正完成。服务器必须等待连接超时，之后才能清除未完成的会话记录，在此期间，服务器连续接收额外的会话请求，最终，服务器因为耗尽用来管理会话的资源而停止响应。
- 缓冲区溢出（Buffer overflow） —— 缓冲区溢出是由于编写和测试代码不谨慎而造成的。针对缓冲区溢出，攻击者可以让系统耗尽资源而不能为合法请求提供服务，或者发送某些系统不能正确处理的数据。
- 泪滴攻击（Teardrop attack） —— 使用重叠IP分片包引起受影响系统重启或中断工作。
- LAND攻击 —— 向某个设备发送数据包，源IP地址和目的IP地址相同，都是攻击目标的地址。
- SMURF攻击 —— SMURF利用ICMP协议发送虚假的ICMP echo request到一个网络广播地址，这将引起所有的系统向某个受害主机返回响应，导致网络饱和。
- 分布式拒绝服务（Distributed denial-of-service, DDoS）攻击 —— 这是一种较新的攻击手段。在DDoS中，成百上千的主机发送大量的请求，受害设备因为无法处理而拒绝服务。



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

D类攻击和滥用



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

E类攻击和滥用

◆ 网络入侵

◆ 主要手段：

- ◆ Spoof攻击 —— 欺骗，简单地说，就是攻击者假扮成其他人实施攻击的过程，其目的在于让通信导向受黑客控制的主机上。一种常见的欺骗攻击就是发生在交换环境中的ARP重定向，黑客可以借此在交换网络中进行嗅探。
- ◆ Trojan（特洛伊木马） —— Trojan是攻击者安装在系统上的软件，这些软件可以让攻击者对受影响系统进行远程控制。Trojan通常会伪装成某种有用的程序，这就增加了迷惑性。
- ◆ 病毒（virus）和蠕虫（worm） —— 蠕虫有复制的能力，特别是在网络中自我复制，而病毒则有赖于其他的分布形式（例如，一个用户通过邮件发送病毒，或者是保存到软盘中）。对付病毒和蠕虫最有效的办法就是使用防病毒软件，并且及时更新系统补丁。
- ◆ 后门（Back door） —— 后门是一种机制，利用它攻击者事后可以重新获取对系统的访问。
- ◆ TCP劫持（hijacking） —— TCP使用序列号来确定通信流的状态。在某些TCP实现中，序列号并不是随机产生的，这就让攻击者找到了插入数据流并劫持会话的机会。其结果是，被攻击的计算机相信攻击者的系统就是最初可信的系统，因而将响应发送到攻击者的系统。
- ◆ Piggy-backing —— 利用合法用户的连接取得系统访问的过程。这种情况发生的原因可能是，用户保持连接开放或者是没有正确地注销。



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

F类攻击和滥用

◆ 刺探（Probing）。用来获取与网络相关的信息，为攻击者实施网络入侵或其他攻击做好准备。

◆ 主要手段：

- 端口扫描（Port scan） —— 用来探测系统上的开放端口，包括所运行的应用程序，它可以产生一个相当深入的正在使用的服务列表。端口扫描的一个对策是只运行必要的服务，并且配置系统不对那些发往未运行服务的请求作出响应。
- 旗标滥用（Banner abuse） —— 许多服务都会使用旗标（banner），其中包含有关系统及服务类型的信息，例如HTTP、FTP和SMTP的旗标。这些信息可能被利用来确定有针对性的漏洞利用方式。一种对策是更改旗标内容，避免敏感信息的泄漏，或者是为外部资源访问设置代理，避免探测工具能与目标主机直接通信。
- 嗅探（Sniffing） —— 嗅探是一种优秀的信息采集机制，可采集的信息包括路由表、MAC地址、网络服务器列表等，有了这些信息，黑客下一步可能会进行欺骗攻击了。



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

目录 Contents

- 1 常见网络攻击
- 2 入侵检测概述
- 3 误用检测模型
- 4 基于特征串匹配的网络攻击检测解析
- 5 常见网络攻击的检测系统开发

上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

入侵检测概述

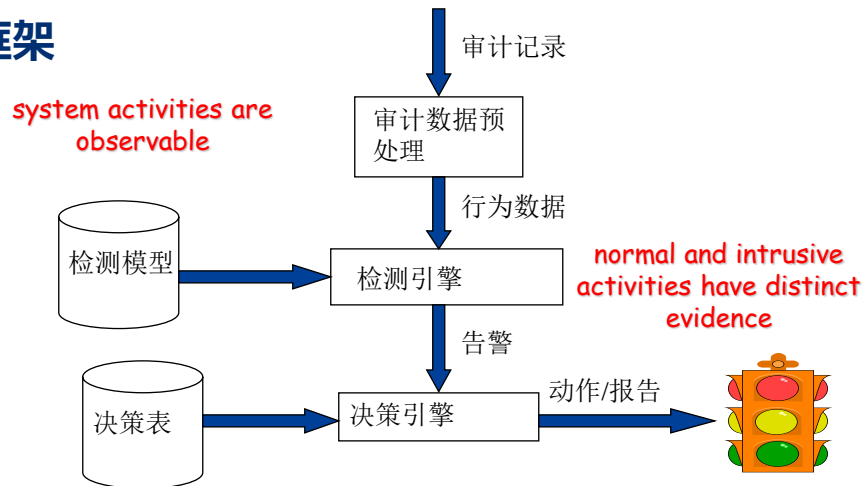


➤ 基本概念

- **入侵：**企图进入或滥用计算机系统的行为。
- **入侵检测**
 - 从计算机网络或系统中的若干关键点收集信息并对其进行分析，从中发现网络或系统中是否有违反安全策略的行为和遭到袭击迹象的一种安全技术
- **入侵检测系统：**进行入侵检测的软件与硬件的组合

入侵检测概述

➤ 系统框架



入侵检测概述

➤ 系统类型

• 异常检测 (Anomaly Detection)

- 总结正常操作应该具有的特征（用户轮廓，比如特定用户的操作习惯与某些操作的频率等）
- 当用户活动与正常行为有重大偏离（后续操作偏离正常统计学意义上的操作模式）时，认为是入侵

• 误用检测 (Misuse Detection)

- 收集非正常操作的行为特征，建立相关的特征库，当监测的用户或系统行为与库中的记录相匹配时，系统就认为这种行为是入侵

目录 Contents

- 1 常见网络攻击
- 2 入侵检测概述
- 3 误用检测模型
- 4 基于特征串匹配的网络攻击检测解析
- 5 常见网络攻击的检测系统开发



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY



上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

误用检测模型

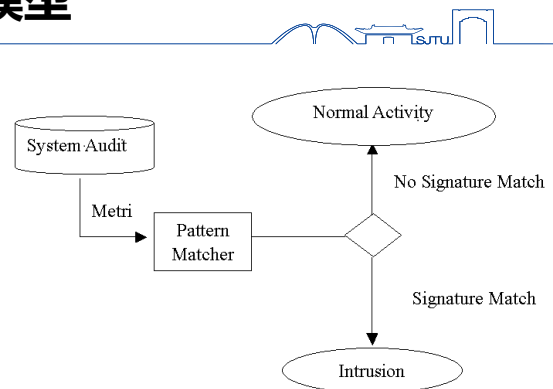
前提

- 系统行为是可观察的
- 正常与入侵有不同的行为证据

攻击特征库

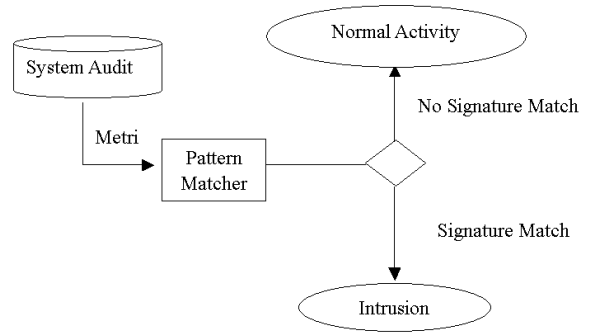
- 当监测的用户或系统行为与库中的记录相匹配时，系统就认为这种行为是入侵

过程

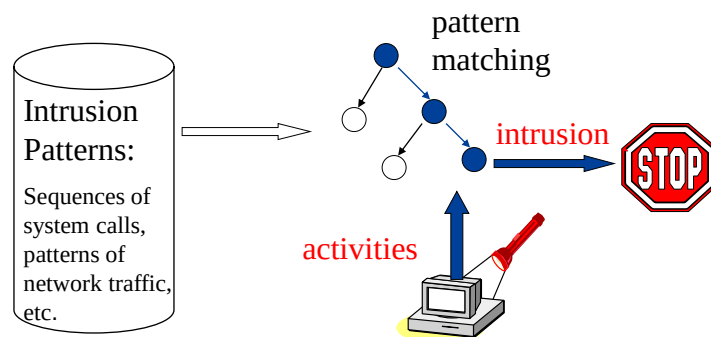


误用检测模型

- **误报**：入侵特征与正常的用户行为匹配
- **漏报**：没有特征能与某种新的攻击行为匹配
- **特点**：
 - 采用特征匹配，误用模式能明显降低错报率，但漏报率随之增加。
 - 攻击特征的细微变化，会使得误用检测无能为力。



误用检测模型



Example: *if* (traffic contains “x90+de[^\r\n]{30}”) *then* “attack detected”

Problems?

Can't detect new attacks

目录 Contents

- 1 常见网络攻击
- 2 入侵检测概述
- 3 误用检测模型
- 4 基于特征串匹配的网络攻击检测解析
- 5 常见网络攻击的检测系统开发

上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

基于特征串匹配的网络攻击检测解析

- **原理：**通过在网络数据流中检查已知的攻击特征串，有效发现网络攻击。
- **核心部分：**
 - **特征库建立：**特征库需要包含比较全面的攻击特征串，覆盖尽可能多的攻击类型，且特征串应该比较准确。
 - **网络数据包获取：**需要利用抓包软件实现网络报文的截取。
 - **特征串匹配算法：**避免低效的——匹配，进行针对性的特征串匹配。
 - **反逃避能力：**在检测设计时，需要考虑对一些攻击或入侵的反逃避能力。

基于特征串匹配的网络攻击检测解析

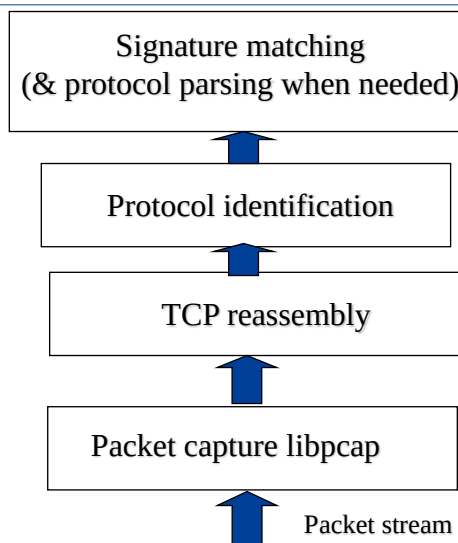
▪ 基础检测功能:

- 1.对TCP报文进行基于特征串匹配的攻击检测
- 2.对单个报文进行检测, 不考虑相邻报文的合并检测
- 3.只要发现数据包中存在攻击特征串, 即认为受到了攻击
- 4.保存攻击特征串在文件中, 系统运行时从指定文件中读取

▪ 可拓展功能:

- 1.添加抗逃避检测, 如合并多个报文进行分析
- 2.改进特征串匹配算法, 提升效率与准确率
3.

基于特征串匹配的网络攻击检测解析





基于特征串匹配的网络攻击检测解析

➤ 利用Libpcap库实现网络数据包获取和基础过滤

- **pcap_lookupdev**: 获取可用的网络设备名。device = pcap_lookupdev(errbuf)
- **pcap_lookupnet**: 获取指定网络设备的IP地址和子网掩码。pcap_lookupnet(device,&ipaddress,&ipmask,errbuf)
- **pcap_open_live**: 打开特定网络设备进行数据包捕获。
phandle = pcap_open_live(device,200,1,500,errbuf) 最大包字节数为200, 设置为混杂模式, 超时时间500
- **pcap_compile** 和 **pcap_setfilter**: 设置数据包过滤器。
 - pcap_compile 将字符串形式的过滤规则编译成bpfprogram结构,
 - pcap_setfilter 将该过滤规则应用到捕获的数据包上。

```
pcap_compile(phandle,&fcode,"ip and tcp",0,ipmask) pcap_setfilter(phandle,&fcode)
```

 设置过滤规则是 "ip and tcp", 意味着只捕获ip和tcp报头的包。
- **pcap_loop**: 开始捕获数据包。会不断捕获数据包, 直到满足一定的条件为止。对于每个捕获到的数据包调用一个回调函数进行处理。
pcap_loop(phandle,-1,pcap_callback,NULL); 指定用于处理的回调函数是pcap_callback



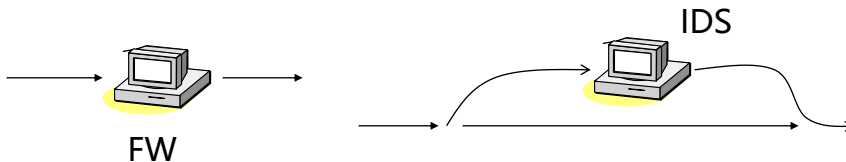
基于特征串匹配的网络攻击检测解析

➤ 基于特征串匹配的攻击检测实现流程

- **攻击模式定义与保存**: 定义攻击模式并保存为文本形式, 设计读取方法。
 - 示例代码使用文本文件保存预定义攻击模式规则, 每行格式为 "攻击模式描述#攻击模式特征"
 - `faxsurvey#faxsurvey?/bin/cat%20/etc/passwd`: 检测是否有通过faxsurvey这个脚本执行cat /etc/passwd命令。
- **网络数据包获取与初步过滤**: 获得符合要求的数据包, 持续监听并对每个获得的数据包调用函数处理。
 - 示例代码使用Libpcap库获取所有ip&tcp的数据包。
- **数据包检查回调函数**: 检查数据包是否是TCP/IP数据包, 然后尝试匹配已知的攻击模式。
 - 获取数据包的IP报头、TCP报头、数据内容。
 - 遍历所有的攻击模式。在每一次循环中, 调用**攻击模式匹配检查**TCP数据是否包含当前的攻击模式。
- **攻击模式匹配检查**: 实现具体的攻击模式匹配算法, 检查给定的数据包是否匹配任何已知的攻击模式。
 - 示例代码使用字符串暴力匹配算法, 逐个字符比较数据包的内容和攻击模式, 直到到达数据包尾或完全匹配, 效率低。
- **告警模块**: 在检测到匹配的攻击模式时输出警告。

基于特征串匹配的网络攻击检测解析

- 防火墙/IPS
 - 主动过滤
 - Fail-close
- 网络IDS
 - 被动监控
 - Fail-open



基于特征串匹配的网络攻击检测解析

➤ 相关抓包工具

- **Wireshark (Ethereal)**
 - 开源数据抓包软件, GUI-based
 - <http://www.wireshark.org>
- **tcpdump**
 - 抓包工具, CLI-based
 - tcpdump for UNIX, windump for Windows
 - <http://www.tcpdump.org>, <http://www.winpcap.org/windump/>

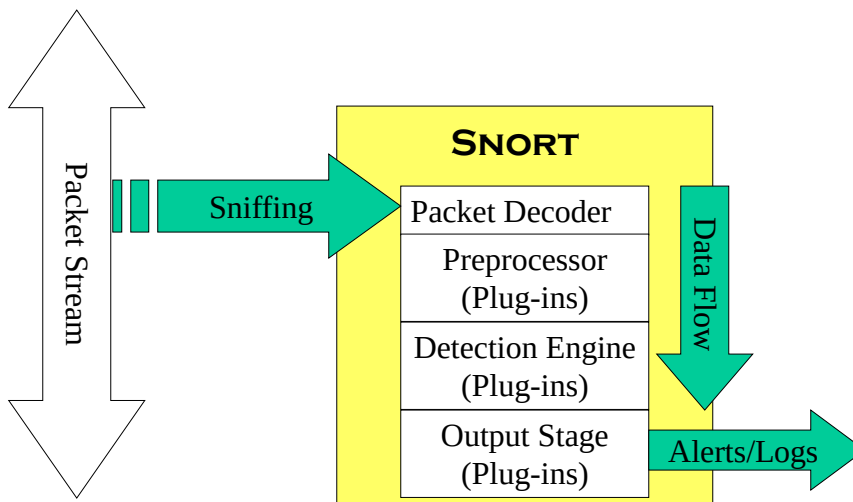
基于特征串匹配的网络攻击检测解析

➤ 相关IDS工具

• Snort

- 轻量级网络IDS
- 实时监测网络中的可疑行为
- <http://www.snort.org>

➤ Snort数据流



➤ Snort规则

- bad-traffic.rules exploit.rules scan.rules
- finger.rules ftp.rules telnet.rules
- smtp.rules rpc.rules rservices.rules
- dos.rules ddos.rules dns.rules
- tftp.rules web-cgi.rules web-coldfusion.rules
- web-frontpage.rules web-iis.rules web-misc.rules
- web-attacks.rules sql.rules x11.rules
- icmp.rules netbios.rules misc.rules
- backdoor.rules shellcode.rules policy.rules
- porn.rules info.rules icmp-info.rules
- virus.rules local.rules attack-responses.rules

➤ Snort规则

- 非常灵活，容易修改

Rule Header	Rule Options
Alert tcp 1.1.1.1 any -> 2.2.2.2 any	(flags: SF; msg: "SYN-FIN Scan");
Alert tcp 1.1.1.1 any -> 2.2.2.2 any	(flags: S12; msg: "Queso Scan");
Alert tcp 1.1.1.1 any -> 2.2.2.2 any	(flags: F; msg: "FIN Scan");

➤ Snort规则

- **alert tcp \$EXTERNAL_NET 27374 -> \$HOME_NET any** (msg:"BACKDOOR subseven 22"; flags: A+; content: "|0d0a5b52504c5d3030320d0a|"; reference:arachnids,485; reference:url,www.hackfix.org/subseven/; sid:103; classtype:misc-activity; rev:4;)
- **alert tcp \$EXTERNAL_NET any -> \$SQL_SERVERS 1433** (msg:"MS-SQL xp_cmdshell - program execution"; content: "x|00|p|00|_|00|c|00|m|00|d|00|s|00|h|00|e|00|i|00|i|00|i|00|i|"; nocase; flags:A+; classtype:attempted-user; sid:687; rev:3;) caught compromise of Microsoft SQL Server

➤ Snort规则

- **alert tcp \$EXTERNAL_NET any -> \$HTTP_SERVERS 80** (msg:"WEB-IIS cmd.exe access"; flags: A+; content:"cmd.exe"; nocase; classtype:web-application-attack; sid:1002; rev:2;) caught Code Red infection
- **alert tcp \$EXTERNAL_NET any -> \$HOME_NET 21** (msg:"INFO FTP \"MKD /\ " possible warez site"; flags: A+; content:"MKD / "; nocase; depth: 6; classtype:misc-activity; sid:554; rev:3;) caught anonymous ftp server

目录 Contents

- 1 常见网络攻击
- 2 入侵检测概述
- 3 误用检测模型
- 4 基于特征串匹配的网络攻击检测解析
- 5 常见网络攻击的检测系统开发

上海交通大学
SHANGHAI JIAO TONG UNIVERSITY

项目任务

1、基本功能

(1) 特征匹配检测

内置攻击特征库，匹配病毒、漏洞利用、Web 攻击、木马远控、恶意命令等固定报文指纹；

覆盖 SQL 注入、XSS、暴力破解等。

(2) 异常行为检测

建立基线：主机并发连接、访问频次、端口访问、带宽、会话时长、内外网访问关系；
识别偏离基线行为：单 IP 高频扫描、短时间大量登录、异常外联陌生 IP、内网横向扩散。

2. 自行扩展检测器的功能

(1) 加密流量检测 (HTTPS/TLS 解密分析)

TLS 代理解密，还原加密 HTTP 载荷，检测加密通道内隐藏攻击、木马 C2 通信；

异常 TLS 指纹识别：恶意程序自制证书、弱加密套件、非常规 SSL 握手行为。

(2) 智能分析与 AI 检测拓展

机器学习模型识别未知攻击（零日攻击、无文件攻击，弥补特征库短板）；

攻击链关联分析：把单条告警串联成完整攻击链路（扫描→漏洞利用→外联 C2→横向扩散）；

误报自动降噪：通过基线、资产重要性、上下文行为过滤重复无效告警

项目要求

1. 可使用C/C++/C#/Java/python等语言，Windows/Linux平台均可，可借助WinPcap、SharpPcap、LibPcap、Libnet等类库；
2. 能检测到非法尝试登录、暴力破解、SQL注入、Web攻击等；
3. 需要实现友好的用户界面；

谢谢！

